
Cuadernillo de Estudio — Clase 3

Términos y Conceptos desde el Punto de Vista de la Seguridad

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. Eventos vs. Incidentes de Seguridad	2
3. El Control de Acceso: Más allá de la contraseña	3
3.1. 1. Identificación	3
3.2. 2. Autenticación	3
3.3. 3. Autorización	3
3.4. 4. No Repudio (y Trazabilidad)	3
4. Defensa en Profundidad	3
5. Protección Criptográfica Básica	4
6. Glosario de conceptos clave	4
7. Autoevaluación	5
8. Respuestas de la Autoevaluación	5
9. Recordatorio: Actividad A02	7
10. Fuentes y bibliografía	7
10.1. Bibliografía obligatoria (según programa)	7
10.2. Bibliografía complementaria (según programa)	7
10.3. Portales y recursos web	7

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Identificar y vincular los elementos de las Tecnologías de la Información (TI) desde el punto de vista de la seguridad.
- Diferenciar con precisión técnica entre **eventos** e **incidentes** de seguridad.
- Comprender y aplicar los mecanismos de **control de acceso** (Identificación, Autenticación, Autorización y No Repudio).
- Entender el modelo de **Defensa en Profundidad** y las capas de protección de un sistema.
- Formar criterios de implementación segura para la resolución del **Cuestionario de Seguridad y Hacking (A02)**.

Cómo usar este cuadernillo

Este material acompaña la Clase 3. Es fundamental para asentar las bases técnicas antes de avanzar hacia la Gestión de Riesgos (Unidad II). Las respuestas de referencia de la autoevaluación se encuentran en la Sección 8.

2. Eventos vs. Incidentes de Seguridad

En el lenguaje cotidiano, solemos usar estas palabras como sinónimos. En la gestión de la seguridad informática (y según estándares como NIST o ISO 27001), tienen significados muy distintos.

Evento de Seguridad

Cualquier **suceso observable** en un sistema o red que pueda ser relevante para la seguridad. Un evento es neutro por naturaleza; simplemente «ocurre».

Incidente de Seguridad

Un evento (o una serie de eventos) que **indica que la seguridad de un sistema ha sido comprometida**, o que existe una amenaza inminente de que lo sea. Un incidente tiene un impacto negativo sobre la Tríada CIA.

Diferenciación en la práctica

- **Evento:** Un usuario ingresa su contraseña incorrectamente en el portal web. (El sistema lo registra en el log, es un suceso observable).
- **Incidente:** El mismo usuario ingresa la contraseña incorrectamente 50 veces en un minuto desde una IP extranjera, y luego el servidor responde con lentitud extrema. (Estamos ante un posible ataque de fuerza bruta o denegación de servicio; la disponibilidad e integridad están en riesgo).

La regla de oro

Todo incidente comienza como un evento, pero **no todo evento es un incidente**. El rol de los sistemas de detección (como los IDS/IPS o los SIEM) es monitorear millones de

eventos para alertar a los analistas solo cuando se configuran como incidentes.

3. El Control de Acceso: Más allá de la contraseña

Para proteger la Confidencialidad y la Integridad, los sistemas utilizan un proceso escalonado que a menudo confundimos. Se divide en cuatro conceptos fundamentales:

3.1. 1. Identificación

Es el acto en el que un usuario **declara** quién es. Es como mostrar tu DNI en la recepción de un edificio.

- *Ejemplos:* Un nombre de usuario, un correo electrónico, un número de legajo, una tarjeta RFID.
- *Característica:* Es público y no secreto.

3.2. 2. Autenticación

Es el proceso mediante el cual el sistema **verifica** que la identidad declarada es real. Es como cuando el guardia del edificio compara la foto de tu DNI con tu rostro.

- *Factores de autenticación:*
 1. **Algo que sabes:** Contraseña, PIN, pregunta de seguridad.
 2. **Algo que tienes:** Token físico, celular (SMS/App), tarjeta inteligente.
 3. **Algo que eres:** Biometría (huella dactilar, FaceID, escáner de iris).

3.3. 3. Autorización

Ocurre *después* de una autenticación exitosa. Determina **qué permisos** tiene el usuario dentro del sistema. Es como cuando el guardia te dice: «Podés subir al piso 3, pero tenés prohibido entrar a la sala de servidores».

- *Mecanismos:* Listas de Control de Acceso (ACL), Roles (RBAC), atributos (ABAC).

3.4. 4. No Repudio (y Trazabilidad)

Garantiza que el usuario **no pueda negar** haber realizado una acción, gracias a que el sistema dejó un registro (log) inalterable y vinculado a su identidad autenticada.

4. Defensa en Profundidad

El diseño de sistemas seguros nunca confía en una única barrera. Si un atacante supera el firewall, no debe encontrar el servidor de base de datos expuesto y sin contraseña.

Defensa en Profundidad

Estrategia de seguridad que emplea **múltiples capas de controles** superpuestos para proteger la información. Si una capa falla, la siguiente debe ser capaz de detener o mitigar la amenaza.

Las capas típicas, desde el exterior hacia el interior (el dato), son:

1. **Física:** Cercos, guardias, control de acceso biométrico al data center, UPS.

2. **Red:** Firewalls, IDS/IPS, segmentación de redes (VLANs), honeypots.
3. **Host (Sistema Operativo):** Antivirus, endurecimiento (hardening) del OS, parches de seguridad.
4. **Aplicación:** Validación de inputs, Web Application Firewalls (WAF), código seguro.
5. **Datos:** Cifrado en tránsito (TLS/SSL) y en reposo, máscaras de datos, backups.

5. Protección Criptográfica Básica

Para proteger los datos (la capa más interna de la Defensa en Profundidad), utilizamos funciones matemáticas. Es vital no confundir estos dos conceptos:

Concepto	Definición	Uso típico
Hashing	Función matemática <i>unidireccional</i> . Convierte un dato en una cadena de longitud fija. No se puede deshacer.	Almacenar contraseñas en bases de datos. Verificar integridad de archivos.
Cifrado	Proceso <i>bidireccional</i> . Codifica un dato usando una clave y se puede descifrar si se posee la clave correcta.	Proteger mensajes (WhatsApp), bases de datos, tráfico web (HTTPS).

Para reflexionar

Si un sistema te permite usar el botón «Recuperar mi contraseña» y te envía tu *misma contraseña original* por correo, ese sistema tiene una **falla de seguridad gravísima**. Significa que no están guardando un Hash de tu contraseña, sino que la tienen guardada en texto plano o con cifrado reversible. Un sistema seguro siempre te pedirá que crees una *nueva* contraseña, porque la original la «olvidó» al aplicarle el Hash.

6. Glosario de conceptos clave

Evento	Suceso observable en un sistema o red.
Incidente	Evento que compromete o amenaza comprometer la Tríada CIA.
Identificación	Declaración de identidad (ej. usuario).
Autenticación	Prueba de la identidad declarada (ej. contraseña, biometría).
Autorización	Permisos otorgados a una identidad autenticada.
No Repudio	Imposibilidad de negar la autoría de una acción.
Defensa en Profundidad	Estrategia de múltiples capas de seguridad superpuestas.
Hash	Función unidireccional para verificar integridad o almacenar credenciales.
Cifrado	Proceso bidireccional para garantizar confidencialidad.
Hardening	Proceso de asegurar un sistema reduciendo su superficie de vulnerabilidad.

7. Autoevaluación

Respondé por escrito y sin apuntes; luego verificá tus respuestas en la Sección 8.

1. Definí con tus palabras la diferencia entre **Evento** e **Incidente**, proporcionando un ejemplo original de cada uno en el contexto de una red Wi-Fi corporativa.
2. Describí los tres primeros pasos del Control de Acceso (Identificación, Autenticación, Autorización) utilizando la analogía de retirar dinero de un cajero automático.
3. ¿Por qué es considerado una mala práctica de seguridad que un sitio web te envíe tu propia contraseña en texto plano al correo cuando usás la función «Olvidé mi contraseña»?
4. Explicá el concepto de **Defensa en Profundidad** y mencioná al menos tres capas aplicables a una aplicación web que procesa pagos con tarjeta de crédito.
5. ¿Cuál es la diferencia fundamental entre un algoritmo de **Hash** y un algoritmo de **Cifrado Simétrico**?

8. Respuestas de la Autoevaluación

Nota para el estudiante

Estas respuestas son **de referencia**. En los parciales y en el cuestionario A02 se valorará la claridad técnica, el uso correcto de la terminología y la capacidad de relacionar los conceptos con la Tríada CIA vista en la Clase 2.

Pregunta 1: Evento vs. Incidente en Wi-Fi

Respuesta

Un **evento** es cualquier suceso observable y registrado por el sistema, sin implicar necesariamente un daño. Un **incidente** es un evento que confirma o indica un compromiso de la seguridad (Confidencialidad, Integridad o Disponibilidad).

Ejemplo en Wi-Fi corporativa:

- **Evento:** Un dispositivo con dirección MAC desconocida se asocia a la red de invitados (Guest) y solicita una IP vía DHCP. El servidor de logs registra la asignación.
- **Incidente:** Ese mismo dispositivo desconocido comienza a realizar un escaneo de puertos (port scanning) hacia la subred de los servidores financieros, y el sistema de detección de intrusos (IDS) dispara una alerta de reconocimiento de red.

Pregunta 2: Control de Acceso en un Cajero Automático

Respuesta

1. **Identificación:** Insertás tu tarjeta de débito en el cajero. La tarjeta le dice al sistema *quién* decís que sos (tu número de cuenta/cliente).
2. **Autenticación:** Ingresás tu PIN de 4 dígitos en el teclado. El sistema *verifica* que ese PIN coincide con el asociado a tu tarjeta (Algo que sabés + Algo que tenés).
3. **Autorización:** El sistema consulta al banco central y determina *qué podés hacer*. Te

autoriza a extraer hasta el límite diario de tu cuenta, pero te denegaría la autorización si intentaras extraer más dinero del que tenés o si la cuenta está bloqueada.

Pregunta 3: La falla de enviar la contraseña por correo

Respuesta

Es una mala práctica gravísima porque viola los principios de **Confidencialidad** y las buenas prácticas de almacenamiento de credenciales.

Si el sistema puede enviarte tu contraseña original, significa que la base de datos no la está almacenando mediante una función **Hash** unidireccional, sino en **textos plano** o con un **cifrado reversible**. Esto implica que cualquier administrador de base de datos, o un atacante que logre vulnerar el servidor, tendrá acceso directo a las contraseñas de todos los usuarios. Un sistema seguro solo almacena el Hash; al olvidarla, el sistema no puede «recordarla», por lo que el procedimiento correcto es generar un token temporal para que el usuario cree una *nueva* contraseña.

Pregunta 4: Defensa en Profundidad en una Web de Pagos

Respuesta

La Defensa en Profundidad es la estrategia de superponer múltiples capas de seguridad para que, si una falla, las siguientes contengan la amenaza. En una web de pagos:

1. **Capa de Red:** Uso de Web Application Firewall (WAF) para bloquear inyecciones SQL y ataques DDoS antes de que lleguen al servidor.
2. **Capa de Aplicación:** Validación y sanitización estricta de todos los inputs del usuario para evitar Cross-Site Scripting (XSS).
3. **Capa de Datos (Tránsito):** Cifrado obligatorio mediante protocolos TLS 1.3 para que los datos de la tarjeta viajen encapsulados por la red.
4. **Capa de Datos (Reposo):** Tokenización de las tarjetas de crédito en la base de datos (no guardar el número real, sino un token inútil si es robado).

Pregunta 5: Hash vs. Cifrado Simétrico

Respuesta

La diferencia fundamental radica en la **reversibilidad** y el **propósito**:

- **Hash (Función de resumen):** Es **unidireccional**. Se usa para verificar la *Integridad* de un dato o almacenar contraseñas. A partir del resultado (hash), es matemáticamente imposible (o inviable) obtener el dato original. No usa «claves» para deshacer el proceso.
- **Cifrado Simétrico:** Es **bidireccional**. Se usa para garantizar la *Confidencialidad*. Utiliza una misma **clave secreta** tanto para cifrar (ocultar) como para descifrar (recuperar) el dato original. Ejemplos: AES.

9. Recordatorio: Actividad A02

Consigna A02 — Cuestionario de Seguridad y Hacking

Responder el cuestionario de Seguridad y Hacking que se habilitará en el campus virtual / aula. Esta actividad evalúa la asimilación de los conceptos de la Unidad I (Clases 1, 2 y 3).

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente»
A. Recopilación de Información	20 %	Utiliza de manera completa fuentes confiables (apuntes, bibliografía) para fundamentar.
B. Interpretación de la consigna	20 %	Interpreta adecuadamente lo que se está preguntando en cada punto del cuestionario.
C. Respuesta	50 %	Responde adecuadamente, con precisión técnica y justificación basada en la Tríada CIA.
D. Consulta	10 %	Comprende adecuadamente la respuesta y el feedback durante la revisión en clase.

10. Fuentes y bibliografía

10.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Elgueta, R. (s.f.). *Guías de Clase unidad I*. Material inédito. UCH.

10.2. Bibliografía complementaria (según programa)

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners, Including Tips on Social Engineering*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.
- ISO/IEC (2005). *Information security management 27001*.
- NIST (National Institute of Standards and Technology). *Computer Security Incident Handling Guide (SP 800-61)*.

10.3. Portales y recursos web

- Portales CERT, NIST, Hispasec y otros relacionados (bibliografía complementaria del programa).
- Glosario de términos de seguridad (OWASP): <https://owasp.org/www-project-web-security-testing-g>